

CONFIDENTIAL - CLIENT SECURITY ASSESSMENT

# Detailed Vulnerability Assessment & Penetration Testing Report

**TATA Advanced Systems Limited (TASL)**

ALS50 Service Management Portal | Current Code, Configuration and Dependency Assessment

---

ASSESSMENT DATE

08 September 2026

REPORT VERSION

2.0 - Detailed Management Review

ASSESSMENT TYPE

Authorized source, configuration and dependency assessment

RECTIFICATION DEADLINE

Within seven calendar days

# Document Control & Management Summary

| FIELD               | VALUE                                                                                                                                           |
|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| Client              | TATA Advanced Systems Limited                                                                                                                   |
| Application         | ALS50 Service Management Portal                                                                                                                 |
| Prepared by         | TechRubix LLP Security Team                                                                                                                     |
| Classification      | Confidential                                                                                                                                    |
| Assessment date     | 08-Sep-2026                                                                                                                                     |
| Scope               | Current repository source, deployment configuration, local application evidence and frontend production dependency graph.                       |
| Testing limitations | No exploitation, production data access, destructive activity, external infrastructure scan, or approved multi-role runtime test was performed. |

## Executive Decision

The current posture is assessed as **Critical**. A confirmed generic API access-control failure, a critical production dependency advisory, high dependency advisories, and an incomplete HTTPS header baseline require emergency corrective action. All reportable findings must be remediated, retested, or formally risk-accepted within **seven calendar days**.

|                                 |                      |                  |                    |
|---------------------------------|----------------------|------------------|--------------------|
| <b>4</b><br>REPORTABLE FINDINGS | <b>2</b><br>CRITICAL | <b>1</b><br>HIGH | <b>1</b><br>MEDIUM |
|---------------------------------|----------------------|------------------|--------------------|

**Evidence integrity:** Findings are limited to current source/configuration evidence and the recorded production dependency audit. The report does not claim successful exploitation, public exposure, or security of untested areas.

## Revision History

| VERSION | DATE        | AUTHOR                      | DESCRIPTION                                                                       |
|---------|-------------|-----------------------------|-----------------------------------------------------------------------------------|
| 1.0     | 08-Sep-2026 | TechRubix LLP Security Team | Current findings assessment                                                       |
| 2.0     | 08-Sep-2026 | TechRubix LLP Security Team | Detailed evidence, methodology, standards, seven-day plan and management sign-off |

# Scope, Methodology & Standards

## Methodology Used

| PHASE                         | METHOD                                                                                                                   | RESULT                                                        |
|-------------------------------|--------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------|
| Scope and asset review        | Reviewed FastAPI backend, React frontend, Compose deployment, Caddy/Nginx configuration and current test assets.         | Assessment boundaries documented.                             |
| Architecture and trust review | Traced generic API route dependencies and compared them to session, administrator and CSRF controls.                     | SEC-001 confirmed by source review.                           |
| Secure code review            | Reviewed route decorators, dependency injection, resource allowlists, state-changing operations and attachment handling. | Access-control gap and existing positive controls identified. |
| Dependency assessment         | Executed <code>npm audit --omit=dev --json</code> against production dependencies.                                       | SEC-002 and SEC-003 confirmed.                                |
| Configuration review          | Compared standard Nginx security headers with the active HTTPS profile mounted by the TLS Compose configuration.         | SEC-004 observed.                                             |
| Risk classification           | Mapped evidence to OWASP, CWE, CVSS v3.1, NIST, ISO/IEC and CIS control objectives.                                      | Management remediation priority established.                  |

## Methodology References

| STANDARD                          | APPLICATION IN THIS ASSESSMENT                                                                            |
|-----------------------------------|-----------------------------------------------------------------------------------------------------------|
| OWASP WSTG / OWASP Top 10:2021    | Coverage model and finding mapping for broken access control, misconfiguration and vulnerable components. |
| OWASP API Security Top 10:2023    | API authorization and object/function-level access-control mapping.                                       |
| CWE and CVSS v3.1                 | Weakness root-cause classification and technical severity prioritization.                                 |
| NIST SP 800-115                   | Planning, review, evidence, analysis, reporting, remediation and retest lifecycle.                        |
| ISO/IEC 27001:2022 and 27002:2022 | Access control, secure configuration, vulnerability management and secure development alignment.          |
| NIST CSF 2.0 and CIS Controls v8  | Governance and engineering control alignment.                                                             |

## Known Limitations

- No current approved target or role-separated test accounts were available for runtime API and BOLA/IDOR validation.
- The active Python interpreter lacks pytest; existing authentication tests could not execute.
- TLS certificates/ciphers, database controls, network segmentation, operating-system hardening, SIEM, injection, XSS, SSRF, file-upload exploitation, and business-logic workflows were not dynamically tested.

# Control Compliance Assessment

| CONTROL AREA                   | EVIDENCE MEETING THE REQUIREMENT                                                                     | GAP / REQUIRED IMPROVEMENT                                                                         | ASSESSMENT  |
|--------------------------------|------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|-------------|
| Identity and access management | Administrator and CSRF dependencies are implemented and used for deletion.                           | Generic list, upsert, bulk-upsert, and replace handlers do not require a session or authorization. | NOT MEETING |
| Session protection             | Session source supports bearer/cookie validation and HTTPS cookies use HttpOnly and strict SameSite. | Route-wide enforcement, expiration, logout, lockout and MFA require dynamic test.                  | PARTIAL     |
| Secure configuration           | Standard Nginx profile includes CSP, nosniff, framing, referrer and permissions controls.            | HTTPS profile contains CSP but does not declare the broader standard header baseline or HSTS.      | NOT MEETING |
| Vulnerability management       | Production dependency audit was executed and evidence retained.                                      | One critical and two high package advisories remain; CI audit gate not evidenced.                  | NOT MEETING |
| File handling                  | Compressed attachment types are rejected for knowledge documents.                                    | Upload/download authorization, malware scanning, traversal and bypass testing required.            | PARTIAL     |
| Logging and monitoring         | Audit-log resource exists in code.                                                                   | Integrity, retention, alerting, SOC visibility and access to logs were not assessed.               | NOT TESTED  |

## International Standards Mapping

| FINDING           | OWASP / API       | ISO/IEC 27001:2022              | NIST CSF 2.0    | CIS V8                                              |
|-------------------|-------------------|---------------------------------|-----------------|-----------------------------------------------------|
| SEC-001           | A01;<br>API1/API5 | A.5.15, A.5.18,<br>A.8.3, A.8.5 | PR.AA,<br>PR.AC | 5 Account Management; 6 Access Control              |
| SEC-002 / SEC-003 | A06               | A.8.8, A.8.32                   | PR.PS,<br>ID.RA | 7 Vulnerability Management; 16 Application Security |
| SEC-004           | A05               | A.8.9, A.8.20, A.8.21           | PR.PS,<br>PR.IR | 4 Secure Configuration; 12 Network Infrastructure   |

# Findings Register

| ID      | FINDING                                               | SEVERITY | EVIDENCE STATUS                    | REQUIRED CLOSURE                      |
|---------|-------------------------------------------------------|----------|------------------------------------|---------------------------------------|
| SEC-001 | Unauthenticated generic records API operations        | CRITICAL | Confirmed by current source review | Day 2 build; Day 5 role retest        |
| SEC-002 | Critical jspdf production dependency advisory         | CRITICAL | Confirmed by current npm audit     | Day 3 patch/retest                    |
| SEC-003 | High xlsx and Tiptap production dependency advisories | HIGH     | Confirmed by current npm audit     | Day 3 patch/mitigation and regression |
| SEC-004 | Incomplete HTTPS response-header baseline             | MEDIUM   | Observed in current configuration  | Day 4 deployed header verification    |

## Dependency Audit Evidence

```
Command: npm audit --omit=dev --json
Production advisory totals: critical=1, high=2, moderate=31, low=0, info=0, total=34.
Critical/high package identities: jspdf (critical, direct, fix available); xlsx (high, direct, no automatic fix);
@tiptap/core (high, transitive, fix available).
```

## Security Test Case Matrix

| AREA                                                     | CURRENT TEST OUTCOME                                           | REQUIRED RETEST                                                                   |
|----------------------------------------------------------|----------------------------------------------------------------|-----------------------------------------------------------------------------------|
| Authentication                                           | Source-only review; automated test suite unavailable.          | Login/logout/reset/session/MFA/lockout tests.                                     |
| Authorization/BOLA                                       | Source review failed for generic record routes.                | Anonymous, ordinary user, group, approver and administrator matrix.               |
| Session/CSRF                                             | Primitives observed; route coverage incomplete.                | Cookie and bearer write operations, missing/invalid CSRF, session expiry.         |
| API and business logic                                   | Generic route access control reviewed; other areas not tested. | Mass assignment, rate limits, lifecycle/approval, concurrency and error handling. |
| Transport/headers                                        | Configuration comparison completed.                            | Actual HTTPS application/API/error response headers and TLS scan.                 |
| Injection, XSS, SSRF, files, database and infrastructure | Not tested.                                                    | Separate approved VAPT/infrastructure test cycle.                                 |

# Detailed Finding: SEC-001

## Unauthenticated Generic Records API Operations

CRITICAL - CONFIRMED

| ATTRIBUTE     | ASSESSMENT RESULT                                                                                                 |
|---------------|-------------------------------------------------------------------------------------------------------------------|
| CVSS v3.1     | 9.8 - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H. Provisional source-based score pending deployed retest.                |
| Affected area | backend/app/api/v1/records.py; generic records API operations.                                                    |
| CWE / OWASP   | CWE-862 Missing Authorization; CWE-639 Authorization Bypass Through User-Controlled Key; OWASP A01 and API1/API5. |

### Description and Business Impact

The collection list, single-record upsert, bulk-upsert and collection-replacement handlers accept only a database dependency. They do not declare validated session, role authorization, ownership/assignment-group scope, or CSRF protection. If deployed as reviewed, an unauthenticated network client could request resource collections and submit individual, bulk, or complete collection replacement operations. This exposes customer, user, incident, contract, correspondence and configuration data to material confidentiality, integrity and availability risk.

### Code Evidence

```
@router.get("/{resource}")
def list_records(resource: str, database: Session = Depends(get_db)):
    ...

@router.put("/{resource}/{record_id}")
def upsert_record(..., database: Session = Depends(get_db)):
    ...

@router.post("/{resource}/bulk-upsert")
def bulk_upsert_records(..., database: Session = Depends(get_db)):
    ...

@router.delete("/{resource}/{record_id}")
def delete_record(..., _: None = Depends(require_administrator),
                  csrf: None = Depends(require_csrf), database: Session = Depends(get_db)):
    ...
```

### Root Cause, Remediation and Retest

Apply validated-session dependencies to every generic route. Add server-side policy enforcement for each resource, action, role, group and ownership boundary. Require CSRF for cookie-authenticated writes. Restrict bulk/replace actions to explicitly authorized administration workflows. Retest anonymous, standard-user, group-member, approver and administrator identities across list/read/upsert/bulk/replace/delete. Anonymous calls must return 401, unauthorized calls 403, and no caller may cross resource ownership/group boundaries.

# Detailed Findings: SEC-002 and SEC-003

SEC-002: Critical jspdf Production Dependency Advisory

CRITICAL - CONFIRMED

The current production dependency audit identifies direct dependency jspdf as critical with a fix available. The application uses PDF/export functionality. The audit confirms package exposure; application-specific exploitation was not dynamically tested.

**Required remediation:** Review the upstream advisory, upgrade to a non-vulnerable release in an isolated branch, regenerate lock data, execute PDF/export regression with untrusted content, rerun the production audit, and retain the remediation evidence.

SEC-003: High xlsx and Tiptap Dependency Advisories

HIGH - CONFIRMED

The audit identifies direct xlsx and the Tiptap editor chain as high. The xlsx audit information includes Prototype Pollution and ReDoS advisories and reports no automatic fix. Exploitability through specific import/editor workflows requires follow-up testing.

**Required remediation:** Replace or update xlsx using supported vendor guidance, enforce workbook size/time/resource limits, upgrade compatible Tiptap packages as a set, and test spreadsheet import/export and rich-text workflows. CI must block or explicitly approve critical/high production audit results.

## Retest Evidence Required

1. Updated package manifest and lockfile.
  2. npm audit --omit=dev --json output after remediation.
  3. PDF, spreadsheet, and editor regression results.
  4. Change approval and rollback record.
  5. Formal risk acceptance only if an advisory cannot be resolved within seven days.

# Detailed Finding: SEC-004

## Incomplete HTTPS Response-Header Baseline

MEDIUM - OBSERVED

The standard Nginx profile sets Content-Security-Policy, X-Content-Type-Options, X-Frame-Options, X-XSS-Protection, Referrer-Policy and Permissions-Policy. The TLS profile mounted by docker-compose.https.yml specifies TLS 1.2/1.3 and CSP only. It does not declare the broader standard header baseline or HSTS. Whether an upstream gateway applies equivalent headers was not verified.

### Configuration Evidence

```
# frontend/nginx.conf
add_header X-Content-Type-Options "nosniff" always;
add_header X-Frame-Options "DENY" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
add_header Permissions-Policy "geolocation=(), microphone=(), camera=()" always;
add_header Content-Security-Policy "..." always;

# frontend/nginx.https.conf
ssl_protocols TLSv1.2 TLSv1.3;
add_header Content-Security-Policy "..." always;
# No matching nosniff, frame, referrer, permissions or HSTS directives observed.
```

### Remediation and Retest

Centralize the approved header baseline in a shared include used by both HTTP/internal and HTTPS configurations. Add HSTS only after validating that all access is permanently HTTPS. At deployment, capture sanitized headers for the application, API and error responses and validate TLS certificates/ciphers separately.

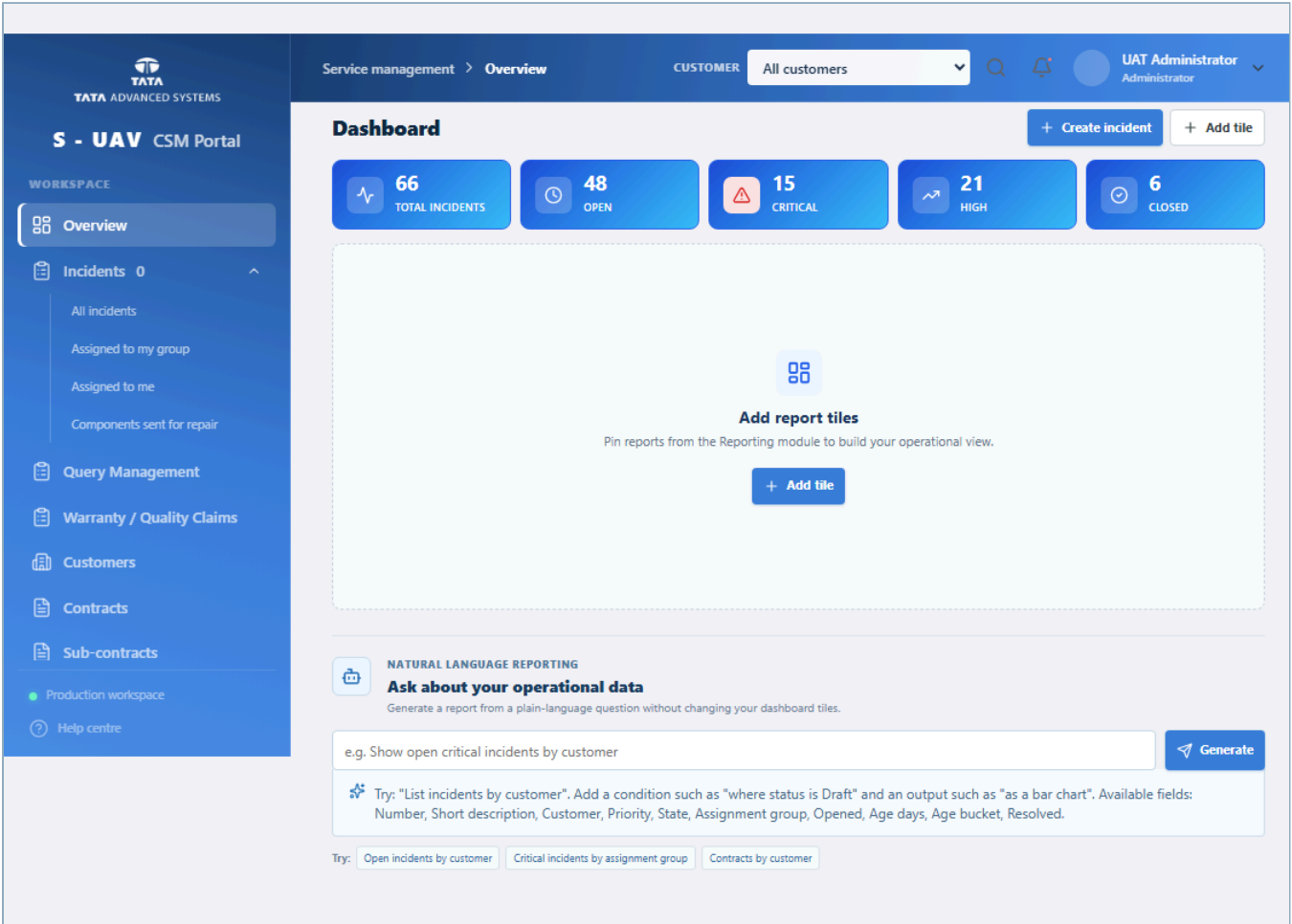
## Positive Controls Observed

| CONTROL                           | EVIDENCE                                                                                                |
|-----------------------------------|---------------------------------------------------------------------------------------------------------|
| Deployment secrets                | Compose expects JWT, database and local administrator secrets through environment values.               |
| Session and CSRF primitives       | Source includes session, administrator and CSRF dependencies, though they are not consistently applied. |
| TLS policy                        | HTTPS Nginx profile explicitly enables TLS 1.2 and TLS 1.3; deployed behavior remains untested.         |
| Compressed attachment restriction | Knowledge-document processing rejects multiple compressed archive types.                                |

# Visible Evidence & Artifact Register

## Application Context Screenshot

Local capture of the ALS50 CSM Portal at <http://127.0.0.1:5173/>, taken during assessment. It confirms the local application context only; it is not proof of compromise, production exposure, or a successful exploit.



## Evidence Register

| ID      | TYPE                           | FINDING / SCOPE    | DESCRIPTION                                                                                           |
|---------|--------------------------------|--------------------|-------------------------------------------------------------------------------------------------------|
| EVD-001 | Current source review          | SEC-001            | Generic records handlers and deletion protection comparison in backend/app/api/v1/records.py.         |
| EVD-002 | Dependency audit               | SEC-002 / SEC-003  | npm audit --omit=dev --json recorded 34 production advisories.                                        |
| EVD-003 | Configuration review           | SEC-004            | Comparison of frontend/nginx.conf and frontend/nginx.https.conf.                                      |
| EVD-004 | Visible application screenshot | Assessment context | ALS50_CSM_Portal_Evidence_2026-10-05.png; local portal capture.                                       |
| EVD-005 | Test limitation                | Assessment scope   | Authentication pytest suite was not executed because pytest is unavailable in the active interpreter. |

**Evidence handling:** No passwords, API tokens, cookies, private keys, PII, or production data are included.  
Future retest request/response evidence must be redacted and assigned an evidence identifier.

# Mandatory Seven-Day Rectification Plan

**Maximum deadline:** All findings must be remediated, independently retested, or formally risk-accepted within seven calendar days from 08-Sep-2026. No closure timeline in this report exceeds one week.

| DAY     | ACTION                                                                                                                   | ACCOUNTABLE OWNER                      | REQUIRED ACCEPTANCE EVIDENCE                                               |
|---------|--------------------------------------------------------------------------------------------------------------------------|----------------------------------------|----------------------------------------------------------------------------|
| Day 0-1 | Open emergency change, appoint executive sponsor and owners; restrict generic records API exposure pending correction.   | Application Owner / Engineering Lead   | Change record, rollback plan, endpoint exposure decision.                  |
| Day 1-2 | Add session, authorization and CSRF enforcement to all generic routes; implement resource/action/ownership/group policy. | Backend Engineering                    | Peer-reviewed change and automated authorization tests.                    |
| Day 2-3 | Patch/replace jspdf; resolve or mitigate xlsx and Tiptap advisories; introduce dependency-audit gate.                    | Frontend Engineering / DevSecOps       | Lockfile, audit output, regression evidence, exception record if required. |
| Day 3-4 | Apply common security-header baseline to HTTPS profile; validate CSP and approve HSTS approach.                          | Platform / DevOps                      | Reviewed configuration and deployed sanitized header captures.             |
| Day 4-5 | Conduct role-separated API retest and confirm fail-closed behavior.                                                      | Security Team / QA                     | 401/403/allowed-path evidence and defect register.                         |
| Day 5-6 | Perform PDF, spreadsheet, editor, synchronization and user-workflow regression testing.                                  | QA / Application Owner                 | Signed regression outcome and release recommendation.                      |
| Day 6-7 | Complete management review, security closure decision, production approval, and retest summary.                          | Security Reviewer / Approval Authority | Signed closure register or time-bounded risk acceptance.                   |

## Closure Conditions

- Every generic read/write operation enforces authentication, authorization, and applicable CSRF validation.
- Anonymous and unauthorized identities receive 401/403 with no information disclosure or data change.
- Critical/high dependency advisories are resolved or formally accepted with compensating controls and an expiry.
- Deployed HTTPS responses conform to the approved header baseline.
- Security, QA, application and release owners approve retained retest evidence.

# Management Review & Formal Sign-Off

## Management Review Record

| REVIEW TOPIC            | REQUIRED DECISION                                                                  | DECISION / NOTES |
|-------------------------|------------------------------------------------------------------------------------|------------------|
| Overall critical risk   | Authorize the seven-day emergency corrective action plan.                          |                  |
| SEC-001 API exposure    | Approve immediate restriction and remediation of generic records API operations.   |                  |
| Dependency remediation  | Approve urgent upgrade/replacement validation for jspdf, xlsx and Tiptap.          |                  |
| HTTPS hardening         | Approve the production response-header baseline and HSTS decision.                 |                  |
| Residual risk exception | Approve or reject any unresolved item with owner, compensating control and expiry. |                  |
| Release/retest          | Require independent security/QA evidence before closure or production release.     |                  |

## Finding Closure and Risk Acceptance

| FINDING | STATUS | RETEST RESULT | RISK OWNER | ACCEPTANCE EXPIRY | APPROVAL |
|---------|--------|---------------|------------|-------------------|----------|
| SEC-001 | Open   | Not tested    |            |                   |          |
| SEC-002 | Open   | Not tested    |            |                   |          |
| SEC-003 | Open   | Not tested    |            |                   |          |
| SEC-004 | Open   | Not tested    |            |                   |          |

## Formal Sign-Off

| ROLE                            | NAME | SIGNATURE | DATE |
|---------------------------------|------|-----------|------|
| TechRubix LLP Security Team     |      |           |      |
| TASL Application Owner          |      |           |      |
| TASL Engineering / DevOps Owner |      |           |      |
| TASL Security Reviewer          |      |           |      |
| TASL Risk Owner                 |      |           |      |
| TASL Approval Authority         |      |           |      |

Sign-off acknowledges receipt of the report, its stated limitations, the maximum seven-day corrective-action deadline, and the requirement for retained retest evidence. Sign-off does not itself accept unresolved risk.

# Detailed Assessment Scope & Rules of Engagement

## In Scope

| ASSESSMENT DOMAIN                                           | COVERAGE STATUS                     | CURRENT EVIDENCE                                                                                       |
|-------------------------------------------------------------|-------------------------------------|--------------------------------------------------------------------------------------------------------|
| Web application and user interfaces                         | Context captured                    | Local portal screenshot and frontend source/configuration review.                                      |
| Authentication, authorization, user management and sessions | Source reviewed                     | Session/admin/CSRF helpers and generic records routes reviewed.                                        |
| APIs and backend services                                   | Source reviewed                     | FastAPI generic records API and handler dependencies reviewed.                                         |
| Database interaction                                        | Source reviewed                     | SQLAlchemy database dependency and record persistence flow reviewed; database runtime not tested.      |
| File upload/download                                        | Partial source review               | Compressed knowledge attachment rejection observed; no upload/download runtime test.                   |
| Input validation, business logic and error handling         | Limited source review               | Request schema field limits and selected application logic reviewed; dynamic validation not performed. |
| Security headers, encryption and deployment                 | Configuration reviewed              | Nginx HTTP/HTTPS profiles and Compose configuration compared.                                          |
| Logging and infrastructure-facing interfaces                | Limited source/configuration review | Audit log resource observed; infrastructure runtime validation not performed.                          |

## Out of Scope / Not Tested

- Social engineering, physical security, denial-of-service, destructive testing, production data modification and denial-of-service testing.
- Third-party infrastructure, cloud services, networks, hosts, firewalls, endpoint protection, OS patching and remote-access services unless separately authorized.
- Internet-facing exposure, open-port discovery, certificate validation, TLS cipher enumeration, database authentication, backup recovery and SIEM integration.
- Authenticated multi-role application behavior because approved test accounts were not supplied.

## Rules of Engagement & Evidence Handling

| CONTROL                | REQUIREMENT                                                                                                                                              |
|------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Authorization boundary | Only local source, configuration and dependency checks completed; no unauthorized endpoint or infrastructure probing was performed.                      |
| Data handling          | No passwords, tokens, session cookies, API keys, private keys, PII, production secrets or production records are included in this report.                |
| Evidence quality       | Every statement is classified as Confirmed, Observed, Potential, Not Tested or Evidence Pending. Confirmed findings have an identified current artifact. |
| Retest evidence        | Future retest artifacts must include date, tester, environment, finding ID, redaction, expected result and actual result.                                |

# Comprehensive Detailed Test Case Matrix

| CATEGORY           | REQUIRED TEST CASES                                                                                                         | CURRENT STATUS                                                   | EVIDENCE / NEXT ACTION                                                          |
|--------------------|-----------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|---------------------------------------------------------------------------------|
| Authentication     | Weak password controls, brute force, account enumeration, MFA, password reset, credential leakage, authentication bypass.   | Not Tested                                                       | Use approved role-separated accounts and retain redacted login/reset artifacts. |
| Authorization      | Horizontal/vertical escalation, IDOR/BOLA, role bypass, administrative functions, API authorization.                        | Confirmed failure for generic routes; remaining tests Not Tested | SEC-001 source evidence; execute resource/action/owner/group matrix.            |
| Session Management | Fixation, timeout, cookie security, Secure, HttpOnly, SameSite, invalidation, concurrent sessions.                          | Partially Observed                                               | Cookie attributes observed in source; runtime session behavior Not Tested.      |
| Input Validation   | SQL/NoSQL/command/LDAP/XPath/XML injection, SSTI, SSRF and CRLF injection.                                                  | Not Tested                                                       | Perform only with approved target and non-destructive test data.                |
| Cross-Site Attacks | XSS, CSRF, clickjacking and DOM-based vulnerabilities.                                                                      | Partially Observed                                               | CSP/frame/CSRF controls reviewed; dynamic validation Not Tested.                |
| File Security      | Unrestricted or malicious upload, path traversal, LFI/RFI and download authorization.                                       | Partially Observed                                               | Compressed archive rejection observed; remaining tests Not Tested.              |
| API Security       | BOLA, broken authentication, excessive data exposure, mass assignment, rate limiting, inventory and error handling.         | Partial / SEC-001 confirmed                                      | Complete authenticated API test matrix during seven-day retest.                 |
| Configuration      | Headers, TLS, HTTP methods, directory listing, debug mode, verbose errors, default credentials and administrative exposure. | Partial / SEC-004 observed                                       | Header configuration reviewed; runtime gateway verification Not Tested.         |
| Data Security      | Sensitive/PII/secrets exposure, encryption at rest/transit and database access control.                                     | Not Tested                                                       | Require approved database, gateway and data-classification assessment.          |
| Business Logic     | Workflow/approval bypass, price manipulation, duplicate transactions, race conditions and privilege abuse.                  | Not Tested                                                       | Require role-separated workflow accounts and business-owner test cases.         |

## Testing Result Legend

| STATUS              | MEANING                                                                                              |
|---------------------|------------------------------------------------------------------------------------------------------|
| CONFIRMED           | Finding or control supported by current assessment evidence.                                         |
| OBSERVED            | Configuration or source condition seen during assessment; deployed behavior remains to be validated. |
| POTENTIAL           | Issue requiring additional validation before it may be treated as a finding.                         |
| NOT TESTED          | Assessment activity was not performed; no security conclusion is implied.                            |
| EVIDENCE<br>PENDING | Future test result requires a redacted artifact before final classification.                         |

# Security Headers, TLS & Cryptography Assessment

## Security Headers

| HEADER                    | EXPECTED                            | OBSERVED SOURCE CONFIGURATION                         | STATUS       | RECOMMENDATION                                                                              |
|---------------------------|-------------------------------------|-------------------------------------------------------|--------------|---------------------------------------------------------------------------------------------|
| Content-Security-Policy   | Present and restrictive             | Present in standard and HTTPS Nginx profiles.         | OBSERVED     | Validate compatibility and deployed application/API/error responses.                        |
| Strict-Transport-Security | Present after HTTPS-only validation | Not declared in reviewed HTTPS profile.               | OBSERVED GAP | Enable after confirming all production access is HTTPS and subdomain policy is appropriate. |
| X-Content-Type-Options    | nosniff                             | Standard profile only; not declared in HTTPS profile. | OBSERVED GAP | Centralize header baseline and verify at gateway.                                           |
| X-Frame-Options           | DENY or SAMEORIGIN                  | Standard profile only; not declared in HTTPS profile. | OBSERVED GAP | Use CSP frame-ancestors plus X-Frame-Options where required.                                |
| Referrer-Policy           | Secure policy                       | Standard profile only; not declared in HTTPS profile. | OBSERVED GAP | Apply strict-origin-when-cross-origin or approved equivalent.                               |
| Permissions-Policy        | Appropriate restrictive policy      | Standard profile only; not declared in HTTPS profile. | OBSERVED GAP | Apply a reviewed feature policy consistently.                                               |

## TLS and Cryptography

| CONTROL                                    | CURRENT EVIDENCE                                                                         | STATUS     | REQUIRED VERIFICATION                                                |
|--------------------------------------------|------------------------------------------------------------------------------------------|------------|----------------------------------------------------------------------|
| TLS version                                | HTTPS Nginx profile declares TLSv1.2 and TLSv1.3.                                        | Observed   | Validate actual listener and reverse-proxy behavior.                 |
| Weak protocols and ciphers                 | No cipher-suite configuration or scan evidence reviewed.                                 | Not Tested | Authorized TLS scan and gateway configuration review.                |
| Certificate validity, chain and expiration | No certificate artifact reviewed.                                                        | Not Tested | Validate CN/SAN, chain, expiration, key size and renewal monitoring. |
| Secure cookies                             | Source sets HttpOnly and strict SameSite; Secure is conditional on HTTPS request scheme. | Observed   | Capture deployed Set-Cookie attributes for login and renewal paths.  |
| Encryption at rest                         | No database/storage encryption evidence supplied.                                        | Not Tested | Review encryption, KMS, backups and key-management records.          |

# Authentication, API, Database & Infrastructure Assessment

## Authentication and Authorization

| AREA                                     | RESULT                                 | EVIDENCE / REQUIRED NEXT STEP                                             |
|------------------------------------------|----------------------------------------|---------------------------------------------------------------------------|
| Login and logout                         | Not Tested                             | Execute approved functional and security test cases.                      |
| Password reset and credential leakage    | Not Tested                             | Test enumeration, reset token lifetime, rate limits and audit logging.    |
| MFA                                      | Not Tested                             | Confirm requirement, enrollment, bypass resistance and recovery controls. |
| Role-based access / privilege escalation | Not Tested except generic route review | Use role matrix and verify horizontal/vertical boundaries.                |
| API authorization / object authorization | Fail by source review                  | SEC-001 must be remediated and retested before release.                   |

## API Security

| CONTROL                                   | STATUS     | EVIDENCE / REQUIRED ACTION                                                               |
|-------------------------------------------|------------|------------------------------------------------------------------------------------------|
| API inventory and versioning              | Partial    | Generic records API and v1 route structure observed; complete inventory Not Tested.      |
| Authentication and authorization          | Fail       | SEC-001 source evidence.                                                                 |
| Excessive data exposure / mass assignment | Potential  | Generic payload persistence requires authenticated field-level review and runtime tests. |
| Rate limiting                             | Not Tested | Confirm gateway/application limits and abuse monitoring.                                 |
| HTTP methods and error handling           | Partial    | Methods visible in source; response behavior Not Tested.                                 |
| API documentation exposure                | Not Tested | Check OpenAPI/docs endpoints in authorized deployment.                                   |

## Database and On-Premises Infrastructure

| AREA                                                                                                | STATUS     | REQUIRED ASSESSMENT                                                                       |
|-----------------------------------------------------------------------------------------------------|------------|-------------------------------------------------------------------------------------------|
| SQL injection, database auth, encryption, privileges, backup security and error leakage             | Not Tested | Approved database security review without exposing credentials or production secrets.     |
| Server hardening, patching, services, local users, remote access and endpoint protection            | Not Tested | OS and endpoint configuration review.                                                     |
| Network segmentation, DMZ, application/database isolation, firewall and ACLs                        | Not Tested | Network architecture and rule-set review.                                                 |
| Web server configuration, directory listing, default files, version disclosure and admin interfaces | Partial    | Nginx config reviewed; deployed behavior requires validation.                             |
| Logging, security monitoring, SIEM, alerting and retention                                          | Not Tested | Review log sources, access controls, retention, alerts and incident response integration. |

# Finding Documentation Standard & Evidence Repository

## Required Structure for Each Confirmed Vulnerability

| FIELD                     | REQUIRED CONTENT                                                                                                                                         |
|---------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Identification            | Finding ID, vulnerability name, severity, CVSS v3.1 score/vector, CWE, OWASP mapping and affected component/endpoint.                                    |
| Impact                    | Professional vulnerability description, realistic business impact, technical impact and risk-rating rationale.                                           |
| Evidence                  | Evidence ID, date, tester, type, redacted request/response, headers, parameter, screenshot/log reference and server/application result where authorized. |
| Root cause and mitigation | Specific code, configuration, infrastructure, database and security-control recommendations as applicable.                                               |
| Retest                    | Exact validation procedure, expected secure result, remediation status and remaining residual risk.                                                      |

## Evidence Categories

| CATEGORY                              | ARTIFACT REQUIREMENTS                                                                                     |
|---------------------------------------|-----------------------------------------------------------------------------------------------------------|
| Authentication and Session Management | Redacted request/response, cookie attributes, account role, date, expected/actual result.                 |
| Authorization and API Security        | Finding ID, endpoint, authorization context, resource/action, HTTP status, response redaction and tester. |
| Input Validation and Files            | Non-destructive test case, input classification, outcome, screenshots/logs and cleanup confirmation.      |
| Configuration and Encryption          | Sanitized headers, TLS output, configuration excerpts, version/date and target ownership.                 |
| Infrastructure and Logging            | Approved architecture/configuration artifacts, log redaction, control owner and validation date.          |
| Business Logic                        | Workflow state, role, expected rule, observed result, approval owner and cleanup record.                  |

**Evidence Pending:** Do not add a request, response, payload, screenshot or proof-of-concept as a confirmed result unless it was generated from an authorized current assessment. Missing artifacts remain Evidence Pending or Not Tested.

## Appendices Index

| APPENDIX | CONTENT                                 |
|----------|-----------------------------------------|
| A        | Vulnerability Summary                   |
| B        | Detailed Test Case Matrix               |
| C        | Evidence Register                       |
| D        | CVSS v3.1 Scoring                       |
| E        | OWASP Mapping                           |
| F        | CWE Mapping                             |
| G        | NIST Mapping                            |
| H        | ISO/IEC 27001 and 27002 Control Mapping |
| I        | CIS Controls Mapping                    |
| J        | Retest Evidence                         |
| K        | Acronyms and Definitions                |

## Acronyms

API: Application Programming Interface; BOLA: Broken Object Level Authorization; CSP: Content Security Policy; CSRF: Cross-Site Request Forgery; CWE: Common Weakness Enumeration; CVSS: Common Vulnerability Scoring System; HSTS: HTTP Strict Transport Security; IDOR: Insecure Direct Object Reference; MFA: Multi-Factor Authentication; PII: Personally Identifiable Information; SIEM: Security Information and Event Management; TLS: Transport Layer Security.